

grt-proc-003162-davara-v1

policies/global/grt-proc-003162-davara-v1.docx

Objetivo

El objetivo de este documento es garantizar que las violaciones de datos personales en términos del art. 4, n.º 12 del RGPD se traten de manera oportuna y adecuada, con el fin de minimizar el impacto potencial sobre los derechos y libertades de las personas afectadas y garantizar el cumplimiento de las leyes de protección de datos.

Ámbito

Este procedimiento se aplica a todos los empleados de Grünenthal en la sede central de Grünenthal y en las filiales alemanas. También establece los principios y normas para todos los procedimientos operativos estándar locales de las filiales de Grünenthal, de conformidad con todas las leyes de protección de datos aplicables.

Responsabilidad

En esta sección se proporciona información sobre las funciones implicadas en el proceso descrito.

Función

Responsabilidad

Empleados

Están alertas ante cualquier sospecha de violación de datos personales en su área y reportan cualquier sospecha de inmediato al responsable global de protección de datos y al responsable alemán de protección de datos (ambos a través de dedataprivacy.de@grunenthal.com) y al departamento global de TI (it-incident@grunenthal.com).

TI global

Evalúa la gravedad de los incidentes de seguridad informática y coordina la respuesta general de TI.

Delegado de Protección de Datos local

Es el responsable de protección de datos designado para la filial de Grünenthal afectada por la violación de datos personales.

Notifica las violaciones de datos personales a las autoridades locales y a las personas afectadas, en consonancia con el departamento jurídico y de cumplimiento normativo local y el director general correspondiente.

Delegado de protección de datos alemán (externo)

Es el responsable de protección de datos designado externamente para la sede central y las entidades alemanas de Grünenthal.

Evalúa las presuntas violaciones de datos personales junto con el responsable global de protección de datos y, si es necesario, con el departamento global de TI, y emite un dictamen sobre si se debe informar a la autoridad supervisora y a las personas afectadas.

Notifica las violaciones de datos personales a todas las autoridades y personas afectadas, en consonancia con el responsable global de protección de datos.

Función

Responsabilidad

y tras la aprobación del responsable global de cumplimiento normativo, el asesor jurídico y la dirección ejecutiva de GRT.

Mantiene y actualiza el registro de presuntas violaciones de datos personales junto con el responsable global de protección de datos.

El responsable global de protección de datos/GDPO como representante del responsable global de cumplimiento

Dirige y coordina la ejecución de todas las medidas necesarias para la gestión de las violaciones de datos personales.

Evalúa las presuntas violaciones de datos personales junto con el responsable alemán de protección de datos y, si es necesario, con el departamento global de TI, y emite un dictamen sobre si se debe informar a la autoridad de control y a las personas afectadas.

Mantiene y actualiza el registro de presuntas violaciones de datos personales junto con el responsable alemán de protección de datos.

Coordinadores de Protección de Datos

Responsables de coordinar todas las acciones necesarias para gestionar la violación de datos personales en su área.

Responsable de cumplimiento global

Aprueba las notificaciones a las autoridades de control y las comunicaciones a las personas afectadas, en coordinación con el asesor jurídico y el miembro del Consejo de Administración responsable del área afectada por la violación de datos personales.

Consejero general

Aprueba las notificaciones a las autoridades supervisoras y las comunicaciones a las personas afectadas, en coordinación con el responsable de cumplimiento normativo global y el miembro del Consejo Ejecutivo responsable del área afectada por la violación de datos personales.

Miembro del Consejo Ejecutivo responsable del área afectada por la violación de datos personales

Aprueba las notificaciones a las autoridades supervisoras y las comunicaciones a las personas afectadas, en coordinación con el responsable global de cumplimiento normativo y el consejero general.

Términos y definiciones

Términos

Definición/Explicación

Incidente de seguridad

Tema general relativo al manejo de malware o vulnerabilidades que pueden tener un impacto grave en los datos o los sistemas (por ejemplo, denegación de servicio). Un incidente de seguridad puede, aunque no necesariamente, dar lugar a una violación de datos personales.

.

Violación de datos personales

Se refiere a una violación de la seguridad que da lugar a la destrucción, pérdida, alteración, divulgación no autorizada o acceso accidental o ilícito a datos personales transmitidos, almacenados o tratados de otro modo, de

conformidad con el artículo 4, apartado 12, del RGPD.

con el art. 4 n.º 12 del RGPD.

Datos personales

Se refiere a cualquier información relacionada con una persona física identificada o identificable («el interesado»). El término «cualquier información» se refiere a cualquier tipo de dato que pueda atribuirse, directa o indirectamente, a una persona física, como el nombre, la edad, la profesión, el cargo en la empresa, los datos de contacto personales o profesionales,

datos relativos a la salud, etc.

Datos afectado (persona afectada)

Persona física que puede ser identificada, directa o indirectamente, en particular mediante referencia a un identificador, como un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios factores específicos de la identidad física, fisiológica, genética, mental, económica, cultural o social de dicha

persona física.

Datos personales seudonimizados

Datos personales que ya no pueden atribuirse a un interesado específico sin el uso de información adicional, siempre que dicha información adicional se mantenga por separado y esté sujeta a medidas técnicas y organizativas para garantizar que los datos personales no se atribuyan a una persona física identificada o identificable. Los datos seudonimizados

no son datos anonimizados.

Tratamiento de datos

Cualquier operación o conjunto de operaciones que se realice sobre datos personales o conjuntos de datos personales, ya sea por medios automatizados o no, como la recopilación, el registro, la organización, la estructuración, el almacenamiento, la adaptación o la modificación, la recuperación, la consulta, el uso , la divulgación , la comunicación , la transmisión o la difusión.

difusión o puesta a disposición de ,

Términos

Definición/Explicación

alineación o combinación, restricción, borrado o destrucción.

Encargado del tratamiento

Se refiere a una persona física o jurídica, autoridad pública, agencia u otro organismo que procesa datos personales en nombre de GRT (por ejemplo, empresas de nóminas o proveedores de servicios en la nube

).

RGPD

El Reglamento General de Protección de Datos 2016/679 establece las normas para la protección de datos personales en la Unión Europea y el Espacio Económico Europeo

.

Sistema Ivanti

Sistema de tickets de TI en el que se gestionan las incidencias relacionadas con las tecnologías de la información.

gestionan.

Herramienta de protección de datos de 2B Advice que sirve como registro

Herramienta de protección de datos que sirve como Registro de Actividades de Tratamiento. actividades

(<http://2bsecure.grtgrou.com/>).

Proceso

Identificación de una posible violación de datos personales

Ser capaz de reconocer las violaciones de datos personales es de suma importancia para minimizar sus posibles efectos y cumplir con las disposiciones establecidas en los artículos 33 y 34 del RGPD. Las violaciones de datos personales pueden provocar daños físicos, materiales o inmateriales a las personas afectadas, como la pérdida de control sobre sus datos personales, la limitación de sus derechos como interesados, la discriminación, el robo de identidad o el fraude, pérdidas económicas, la reversión no autorizada de la seudonimización, daños a la reputación y la pérdida de confidencialidad de los datos personales protegidos por el secreto profesional. Además, las violaciones de datos personales también pueden acarrear sanciones importantes para GRT.

Las violaciones de datos personales comprenden tanto las violaciones no autorizadas como las accidentales y abarcan los siguientes casos, siempre que se vean afectados datos personales:

Las violaciones de la disponibilidad se refieren a los casos en los que se produce una pérdida o destrucción accidental o no autorizada de datos personales.

Las violaciones de la confidencialidad se producen cuando se produce una divulgación o un acceso no autorizado o accidental a datos personales que deben permanecer confidenciales.

Las violaciones de la integridad se refieren a los casos en los que se produce una alteración no autorizada o accidental de los datos personales.

Algunos ejemplos de violaciones de datos son:

Se pierde o se roba un dispositivo que contiene datos personales, como una computadora portátil, una memoria USB, un disco duro externo o un teléfono móvil.

Se pierde o se roba la clave de descifrado de un dispositivo cifrado.

Los datos personales se comparten o se envían a un destinatario no deseado, incluso cuando ese destinatario es un empleado de GRT (por ejemplo, correos electrónicos, cartas o faxes enviados al destinatario equivocado

o un archivo que contiene datos personales almacenado en la unidad compartida equivocada).

Se pierde o se roba una lista con datos personales, como nombres o datos de contacto de clientes o empleados, ya sea almacenada digital o físicamente.

Un sistema o red en el que se almacenan o comparten datos personales es pirateado.

Un corte de energía que dura varios minutos y que hace que los datos personales no estén disponibles temporalmente.

Un fallo del sistema permite a todos los empleados o terceros acceder a datos personales de otras personas que deben permanecer confidenciales.

Un correo electrónico enviado a un profesional sanitario que incluye por error los nombres de otros profesionales sanitarios que también han recibido el mismo correo electrónico (por ejemplo, con fines de marketing).

fines de marketing).

Una empresa que procesa datos personales en nombre de GRT (por ejemplo, empresas de nóminas, agencias de viajes, agencias de marketing, proveedores de servicios en la nube, etc.) experimenta

una de las situaciones descritas anteriormente.

Las violaciones de datos personales pueden no ser fácilmente reconocibles, por lo que cualquier empleado que sospeche o dude de que un incidente de seguridad pueda dar lugar a una violación de datos personales debe informar inmediatamente al responsable global de protección de datos, al responsable alemán de protección de datos y al departamento global de TI. Esto último se aplica incluso si se desconoce si los datos personales se han visto afectados.

Notificación de la sospecha de violación de datos al responsable global de protección de datos, al responsable alemán de protección de datos y al departamento global de TI

Las leyes de protección de datos y, en particular, el RGPD exigen que las violaciones de datos personales se notifiquen a las autoridades de control competentes en un plazo máximo de 72 horas desde que GRT tenga conocimiento de la violación, a menos que sea improbable que la violación de datos personales suponga un riesgo para los derechos y libertades de las personas físicas.

Por lo tanto, todas las sospechas de violaciones de datos deben notificarse inmediatamente, sin demoras indebidas, al responsable global de protección de datos y al responsable alemán de protección de datos (ambos a través de dataprivacy.de@grunenthal.com) y al departamento de TI global (it-incident@grunenthal.com).

Al mismo tiempo, toda la documentación relacionada también debe remitirse al responsable global de protección de datos, al responsable alemán de protección de datos y a TI global. Además, el responsable global de protección de datos, el responsable alemán de protección de datos y/o TI global pueden solicitar información adicional para comprender mejor las características de la violación de datos personales en un plazo breve, con el fin de poder cumplir con los plazos requeridos.

Preferiblemente, el coordinador de protección de datos responsable del área en la que se ha producido la violación de datos personales coordinará todas las acciones necesarias para satisfacer las solicitudes del responsable global de protección de datos, el responsable alemán de protección de datos y/o el departamento de TI global.

Evaluación de la sospecha de violación de datos

Se debe realizar lo antes posible, y en cualquier caso en las primeras 72 horas tras tener conocimiento de ella, una evaluación para determinar si la sospecha de violación de datos personales debe ser comunicada a las autoridades.

La evaluación debe ser realizada por el responsable global de protección de datos, el responsable alemán de protección de datos y, si es necesario, el departamento global de TI.

Tras analizar el caso, el responsable global de protección de datos, el responsable alemán de protección de datos y, si es necesario, el departamento global de TI, formarán y compartirán su opinión sobre si la violación de datos personales debe ser notificada a las autoridades y a las personas afectadas con el responsable global de cumplimiento normativo y el asesor jurídico. Si se considera necesario, el responsable global de protección de datos y el responsable alemán de protección de datos también asesorarán sobre si deben participar otros responsables locales de protección de datos o equipos jurídicos, en caso de que la violación de datos personales afecte a otras entidades de GRT.

Notificación y comunicación de la violación

La transparencia permite a las personas afectadas reaccionar y proteger sus propios intereses cuando se produce una violación de datos personales. Además, ayuda a comprender los factores subyacentes que causaron la violación de datos personales y proporciona a los reguladores la información que necesitan para desempeñar sus funciones de supervisión.

Notificación a una autoridad supervisora

El responsable global de protección de datos, el responsable alemán de protección de datos y, si es necesario, el departamento global de TI, emitirán un dictamen sobre si la violación de datos personales debe notificarse a las autoridades.

Cuando el responsable global de protección de datos y el responsable alemán de protección de datos (si es necesario, en coordinación con el departamento global de TI) concluyan que la violación de datos personales debe ser notificada a las autoridades, dicha opinión se compartirá con el responsable global de cumplimiento y el consejero general, quienes decidirán en última instancia sobre dicha notificación en coordinación con el miembro del Consejo Ejecutivo responsable del área afectada por la violación de datos personales.

La notificación a las autoridades será realizada por el responsable de protección de datos alemán o local, según corresponda. Además, si la violación de datos personales debe notificarse a una autoridad supervisora no alemana, la notificación se realizará en coordinación con el departamento jurídico y de cumplimiento normativo local y el director general correspondiente.

Comunicación de la violación de datos personales al interesado

El responsable global de protección de datos, el responsable alemán de protección de datos y, si es necesario, el departamento global de TI, deben emitir un dictamen sobre si la violación de datos personales también debe comunicarse a las personas afectadas. Esta comunicación tiene por objeto ayudar a las personas afectadas a tomar las medidas necesarias para protegerse.

En cualquier caso, la decisión final sobre la comunicación de una violación de datos personales a las personas afectadas la tomarán el responsable global de cumplimiento normativo y el consejero general, en coordinación con el miembro del Consejo de Administración responsable del área afectada por la violación de datos personales.

La comunicación a las personas afectadas correrá a cargo del responsable alemán o local de protección de datos, según corresponda. Además, cuando la violación de datos personales afecte a una filial de GRT, la comunicación se llevará a cabo en coordinación con el departamento jurídico y de cumplimiento normativo local y el director general correspondiente.

Mantenimiento de un registro de violaciones de datos personales

El responsable global de protección de datos y el responsable alemán de protección de datos llevarán un registro de todas las sospechas de violaciones de datos personales, ya sean confirmadas o no.

Además, si la violación de datos personales está relacionada con un incidente de seguridad informática, deberá ser registrada en la herramienta Ivanti por el departamento de TI global.

Violaciones de datos personales por parte de terceros (procesadores de datos) que tratan datos personales en nombre de GRT

GRT es responsable de las violaciones de datos personales de las actividades de terceros (es decir, procesadores de datos) que están contratados para procesar datos personales en su nombre (es decir, proveedores que prestan servicios en la nube o de nómina, etc.).

Dichas relaciones comerciales deben regirse siempre por un contrato que estipule que el encargado del tratamiento de datos ayudará a GRT a garantizar el cumplimiento de las leyes de privacidad de datos, incluida la obligación de informar a GRT sin demora injustificada de las sospechas de violaciones de datos personales. Si el encargado del tratamiento de datos descubre otros detalles relacionados con la violación de datos personales,

deberá comunicarlos a GRT tan pronto como estén disponibles.

Como regla general, las actividades descritas en esta política (es decir, evaluar la violación de datos personales, decidir si la violación de datos personales debe notificarse a las autoridades o comunicarse a las personas afectadas, etc.) siempre serán realizadas por GRT y no por un procesador de datos. Cualquier desviación de esta regla siempre deberá ser aprobada previamente por el Director de Cumplimiento Global y el Asesor Jurídico.

Prevención de violaciones de datos personales

GRT está siempre expuesta a violaciones de datos personales, incluso si se han adoptado las medidas técnicas y organizativas adecuadas. Sin embargo, la probabilidad de que se produzcan violaciones de datos personales puede minimizarse si se toman ciertas medidas de protección. Además, el impacto de una violación de datos personales en los derechos y libertades de las personas afectadas también puede reducirse en caso de que el riesgo se materialice.

La probabilidad de que se produzca una violación de datos personales y el impacto de la misma pueden minimizarse si, por ejemplo:

Se identifican de antemano los procesos y flujos de datos en los que intervienen datos personales.

Se identifican las ubicaciones (ya sean físicas o digitales) donde se almacenan los datos personales.

Se aplican las medidas técnicas y organizativas adecuadas para proteger los datos personales (es decir, cifrado, seguridad y controles de acceso) y estas han sido evaluadas por las áreas pertinentes, como la de TI.

evaluadas por los departamentos pertinentes, como el de TI.

Los datos personales altamente sensibles o confidenciales se marcan como tales y se protegen en consecuencia.

Se han aplicado técnicas de seudonimización o anonimización a los datos personales siempre que ha sido posible.

Usted comprende los principales riesgos para los datos personales en su área y los controles establecidos para mitigarlos.

Las actividades de tratamiento que afectan a los datos personales se registran y se mantienen actualizadas en el registro de 2B Advice.

GRT elige terceros fiables para el tratamiento de datos personales.

Los terceros que tratan datos personales en nombre de GRT están obligados contractualmente a ayudar a GRT a cumplir los requisitos legales en materia de protección de datos.

Plantillas y formularios necesarios para el proceso

Plantilla para comunicar las violaciones de datos personales a las personas afectadas.

Referencias

Procedimiento operativo estándar sobre la gestión de incidentes de seguridad.

Índice histórico

n/a

Revisión/n.º de documento

Descripción de los cambios

01

Nuevo documento

8. Apéndice 1: México

8.1. Objetivo

El presente Apéndice tiene por objeto adaptar la Política Global para vulneraciones de seguridad de Grünenthal a la normativa mexicana en materia de protección de datos personales.

8.2 Ámbito

El presente Apéndice y los procedimientos que en él se establecen serán aplicables cuando ocurra una vulneración de datos personales y, por motivo del territorio de origen de los datos, los efectos del tratamiento o cualquier otro criterio previsto en la legislación aplicable o en el derecho internacional, resulte aplicable la normativa mexicana en materia de protección de datos personales.

Este Apéndice deberá de ser complementado con las políticas locales en materia vulneraciones de seguridad o de datos personales adoptadas por las filiales de GRT, en particular por Grünenthal de México, S.A. de C.V., las cuales desarrollan con mayor detalle los roles, procedimientos y metodologías necesarios para garantizar el cumplimiento de la normativa mexicana.

8.3 Responsabilidad

El segmento 3, Responsabilidades, de la Política Global de GRT se mantendrá con las siguientes modificaciones:

Empleados: se sustituye la obligación de notificar al responsable alemán de protección de datos personales; en su lugar, deberán notificar al Equipo de Protección de Datos correspondiente a la filial. En caso de ser la filiar en México (Datos.PersonalesMX@grunenthal.com).

TI Global: sin adecuaciones.

Equipo de Protección de Datos de la Filial (denominado en México como Departamento de Datos Personales): se elimina la obligación de notificar la vulneración a las autoridades correspondientes al no ser un requisito legal en México.

Delegado de Protección de Datos Mexicano (externo): se elimina la obligación de crear un dictamen para evaluar la necesidad de notificar a las autoridades correspondientes, al no ser esta notificación una obligación legal.

Responsable Global de Protección de Datos Personales (GDPO), como representante del Responsable Global de Cumplimiento: sin adecuaciones.

Coordinadores de Protección de Datos: sin adecuaciones.

Responsable Global de Cumplimiento: se elimina su obligación de aprobar las notificaciones a la autoridad a las autoridades correspondientes, al no ser dicha notificación una obligación legal.

Consejero General: se elimina su obligación de aprobar las notificaciones a la autoridad, al no ser dicha notificación una obligación legal.

Miembro del Consejo Ejecutivo responsable del área afectada: se elimina su obligación de aprobar las notificaciones a la autoridad, al no ser dicha notificación una obligación legal.

8.5. Proceso.

8.5.1. Identificación de una posible violación de datos personales

El proceso establecido en el segmento 5.1 Identificación de una posible violación de datos personales sigue siendo válido para su aplicación en México.

8.5.2. Notificación de la sospecha de violación de datos al responsable global de protección de datos, al Equipo de Protección de Datos y al departamento global de TI.

El proceso establecido en el segmento 5.2. Notificación de la sospecha de violación de datos al responsable alemán de protección de datos y al departamento global de TI de la política global de GRT sigue siendo válido, solo con las siguientes modificaciones:

No existe una obligación de notificar a las autoridades en la legislación mexicana, aunque en caso de que la información pueda afectar de forma significativa los derechos patrimoniales o morales de las personas titulares, se deberá de notificar de manera inmediata a los titulares.

Se reemplaza la obligación de notificar una posible violación de datos y remitir toda la documentación correspondiente al responsable alemán de protección de datos personales; dicha notificación y entrega de información deberá realizarse al Equipo de Protección de Datos de la filial correspondiente. En el caso de la filial de GRT en México (Datos.PersonalesMX@grunenthal.com).

El coordinador de protección de datos responsable deberá cumplir con las solicitudes del Equipo de Protección de Datos de la filial correspondiente:

8.5.3. Evaluación de sospecha de violación de datos.

El proceso establecido en el segmento 5.3 Evaluación de la sospecha de violación de datos de la política global de GRT se mantiene vigente; sin embargo, en lugar de centrarse en la necesidad de notificar a la autoridad correspondiente, se enfocará en la evaluación de la necesidad de notificar a los titulares cuyos datos hayan sido vulnerados.

La evaluación deberá realizarse conjuntamente por el responsable global de protección de datos, el equipo de protección de datos de la filial correspondiente y, de ser necesario, el departamento global de TI. Dicho análisis deberá determinar si los datos afectados comprometen de manera significativa los derechos morales o patrimoniales de los titulares.

Esta evaluación deberá de realizarse de manera escrita y documentada.

8.5.4 Notificación y comunicación de la violación.

8.5.4.1. Notificación a una autoridad supervisora.

El subsegmento 5.4.1 Notificación a una autoridad supervisora de la política global de GRT no es aplicable en México al no existir una obligación legal.

8.5.4.2. Comunicación de la violación de datos personales al interesado.

La subsección 5.4.2 Comunicación de la violación de datos personales al interesado se mantiene vigente, con las siguientes modificaciones:

Se sustituye al responsable alemán como la entidad corresponsable de emitir el dictamen sobre la necesidad de notificar a los interesados y de realizar dicha comunicación, estableciendo en su lugar al Equipo de Protección de Datos de la filial correspondiente.

8.5.5. Mantenimiento de un registro de violaciones de datos personales.

Se mantiene el proceso establecido en la sección 5.5 de las políticas globales de GRT, solo se modifica a la entidad encargada de dicho que será el Equipo de Protección de Datos de GRT de la filial correspondiente.

8.5.6. Violación de datos personales por parte de terceros (procesadores de datos)

Se mantiene el proceso establecido en el segmento 5.6 Violaciones de datos Personales por parte de terceros (procesadores de datos) que tratan datos personales en nombre de GRT.

8.5.7. Prevención de violaciones de datos personales.

El proceso establecido en el segmento 5.7 Prevención de violaciones de datos personales de GRT se sigue aplicando de manera íntegra en México.

8.5.8. Plantilla y formularios necesarios para el proceso.

Se agrega los siguientes documentos que funcionan como complementos a los procesos previamente establecidos.

Política de atención a vulneraciones de seguridad de datos personales de Grünenthal de México, S.A. de C.V, filial de GRT en la región.